

Security and Protection of Systems

Lecture 2 *Attacks, Threat and Malware*

Dr. Zaher Haddad

1

Outlines

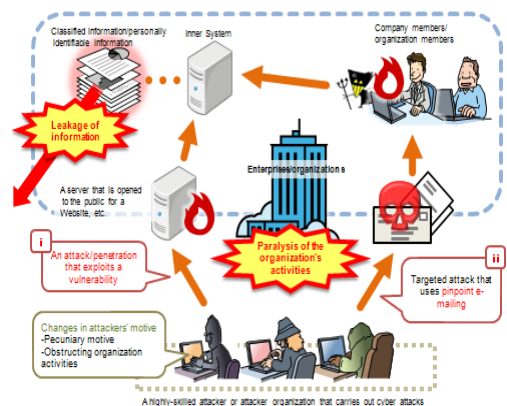
- *Information Security Terminologies*
- *Defending Against Attacks*
 - *Difficulties*
 - *Considerations*
- *Malicious software (Malware)*
- *Psychological Approaches*

Outlines

- Information Security Terminologies
- Defending Against Attacks
 - Difficulties
 - Considerations
- Malicious software (Malware)
- Psychological Approaches

Attack

- Any attempt to **expose, alter, disable, destroy, steal, or gain** information through unauthorized access to or make unauthorized use of an asset. (**Asset**: Item that has value)



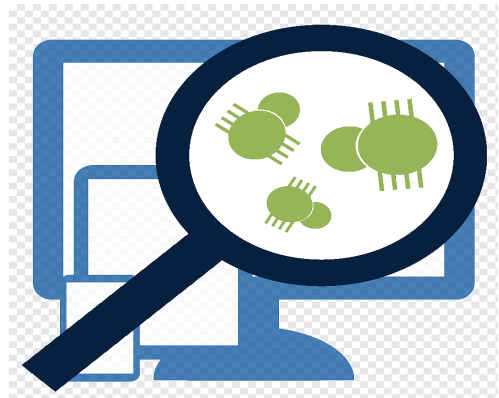
Threat

- A potential negative action or event facilitated by **vulnerability** that results in an **unwanted impact** to a computer system or application.



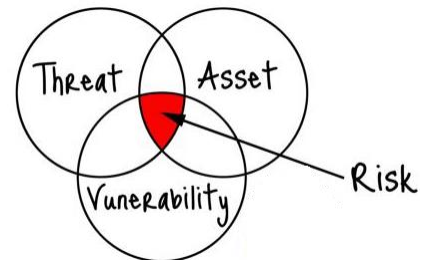
Vulnerability

- **Flaw** or **weakness** that allows a threat agent to bypass security
- Can be exploited by attacker to perform unauthorized actions within a computer system.



Risk

- A situation that involves exposure to some type of danger
- Risk response techniques:



1. **Accept** - risk is acknowledged but no steps are taken to address it
2. **Transfer** - transfer risk to a third party
3. **Avoid** - identifying risk but making the decision to not engage in the activity
4. **Mitigate** - attempt to address risk by making the risk less serious

Threat Actors

- A person or element with power to carry out a threat
- A generic term used to describe individuals who launch attacks against other users and computers
- Different groups of threat actors can vary widely, based on:
 1. Attributes
 2. Funding and resources
 3. internal or external
 4. Intent and motivation



Threat Actors types

1- Hacktivists - attackers who attack for ideological reasons that are generally not as well-defined as a cyberterrorist's motivation



Examples:

1. Breaking or changing the contents of website to make a political statement
2. Disabling website belonging to a bank because the bank stopped accepting payments that were deposited into accounts belonging to the hacktivists

Threat Actors types

2- Nation state actor - an attacker commissioned by the governments to attack enemies' information systems

- May target foreign governments or even citizens of the government who are considered hostile or threatening



Threat Actors types

3- Advanced Persistent Threat (APT) -

Threat targets highly sensitive economic, proprietary, or national security information



Threat Actors types

4- Insiders: Employees, contractors, and business partners , Over 58 % of breaches attributed to insiders

Examples :



1. Health care worker may publicize celebrities' health records
2. Stock trader might conceal losses through fake transactions
3. Employees may be bribed or coerced into stealing data before moving to a new job

Outlines

- *Information Security Terminologies*
- *Defending Against Attacks*
 - *Difficulties*
 - *Considerations*
- *Malicious software (Malware)*
- *Psychological Approaches*

13

Difficulties in Defending Against Attacks

1. **Universally connected devices:** Attackers from anywhere in the world can send attacks
2. **Increased speed of attacks:** Attackers can launch attacks against millions of computer within minutes
3. **Greater sophistication of attacks:** Attack tools vary their behavior so the same attack appears differently each time
4. **Availability and simplicity of attack tools:** Attacks are no longer limited to highly skilled attackers
5. **Faster detection of vulnerabilities:** Attackers can discover security holes in hardware or software more quickly

14

Difficulties in Defending Against Attacks

5. **Delays in security updating:** Vendors are overwhelmed trying to keep pace updating their products against the latest attacks
6. **Weak security update distribution:** Many software products lack a means to distribute security updates in a timely fashion
8. **Distributed attacks:** Attackers use thousands of computers in an attack against a single computer or network
9. **Use of personal devices:** Enterprises are having difficulty providing security for a wide array of personal devices
10. **User confusion:** Users are required to make difficult security decisions with little or no instruction

Outlines

- *Information Security Terminologies*
- *Defending Against Attacks*
 - *Difficulties*
 - *Considerations*
- *Malicious software (Malware)*
- *Psychological Approaches*

Considerations in defending Against Attacks

1- Layering

- Information security must be created in layers
 - A single defense mechanism may be easy to circumvent
 - Making it unlikely that an attacker can break through all defense layers
- Layered security approach (also called defense-in-depth)
 - Can be useful in resisting a variety of attacks
 - Provides the most comprehensive protection



ITNM3312, Security & Protection of Systems

17

Considerations in defending Against Attacks

2- Limiting

- Limiting access to information:
 1. Reduces the threat against it
 2. Only those who must use data should be granted access
 3. Should be limited to only what they need to do their job
- Methods of limiting access
 - Technology-based - such as file permissions
 - Procedural - such as prohibiting document removal from premises



18

Considerations in defending Against Attacks

3- Diversity

- Layers must be different (diverse), If attackers penetrate one layer: Same techniques will be unsuccessful in breaking through other layers
- Breaching one security layer does not compromise the whole system
- Example :Using security products from different manufacturers
 - Groups who are responsible for regulating access (control diversity) are different



Consideration in defending Against Attacks

4- Obscurity

- Obscuring inside details to outsiders by not revealing details
- Examples:
 1. Operating system version
 2. Brand of software used
- Difficult for attacker to devise attack if system details are unknown



Consideration for defending Against Attacks

5- Simplicity

- Nature of information security is complex
- Complex security systems:
 - Can be difficult to understand and troubleshoot
 - Are often compromised for ease of use by trusted users
- A secure system should be simple from the inside
 - But complex from the outside



Outlines

- *Information Security Terminologies*
- *Defending Against Attacks*
 - *Difficulties*
 - *Considerations*
- *Malicious software (Malware)*
- *Psychological Approaches*

Malicious software (Malware)

- Any software intentionally designed to cause damage to a computer, server, client, or computer network
- Enters a computer system without the owner's knowledge or consent
- Uses a threat vector to deliver a malicious "payload" that performs a harmful function once it is invoked
- Malware is a general term that refers to a wide variety of damaging or annoying software



Malicious software (Malware)

Malware can be classified by the using the primary trait that the malware possesses:

1. **Circulation** - spreading rapidly to other systems to impact a large number of users
 - Viruses and Worms
2. **Infection** - how it embeds itself into a system
 - Trojans - Ransomware- Crypto-malware
3. **Payload capabilities** - what actions the malware performs
 - Collect data - Delete data - Modify system security settings - Launch attacks

Circulation (1) - Virus

1. **Computer virus** is a malicious computer code that reproduces itself on the same computer
2. **Program virus** infects an executable program file
3. **Macro** is a series of instructions that can be grouped together as a single command
 - Common data file virus is a **macro virus** that is written in a script known as a macro
 - Most viruses today go to great lengths to avoid detection (called an armored virus)



Armored virus infection techniques

1. **Swiss cheese infection** - viruses inject themselves into executable code
 - Virus code is "scrambled" to make it more difficult to detect
2. **Split infection** - virus splits into several parts
 - Parts placed at random positions in host program
 - The parts may contain unnecessary "garbage" code to mask their true purpose
3. **Mutation** - some viruses can mutate or change
 - An oligomorphic virus: changes its internal code to predefined mutations.
 - A polymorphic virus: completely changes from its original
 - A metamorphic virus: can rewrite its own code and appear different each time.

Circulation (1) - Worm

- **Worm** - malicious program that uses a computer network to replicate
 - Sends copies of itself to other network devices
- Worms may:
 1. Consume resources or
 2. Leave behind a payload to harm infected systems
- Examples of worm actions
 - Deleting computer files
 - Allowing remote control of a computer by an attacker



Circulation (1)

Action	Virus	Worm
Mechanism	Inserts malicious code into a program or data file	Exploits a vulnerability in an application or operating system
Spreading	User transfers infected files to other devices	Uses a network to travel from one computer to another
File infection	Yes	No
Does there need to be user action for it to spread?	Yes	No

Infections (2) - Trojans

- **Trojan** - an executable program that does something other than advertised
 - Contain hidden code that launches an attack
 - Sometimes made to appear as data file
- Example
 - User downloads "free calendar program"
 - Program scans system for credit card numbers and passwords
 - Transmits information to attacker through network
 - Remote access Trojan (RAT) - gives the threat actor unauthorized remote access to the victim's computer by using specially configured communication protocols



Infections (2) - Ransomware

- **Ransomware** - prevents a user's device from properly operating until a fee is paid
 - Is highly profitable
- A variation of ransomware displays a fictitious warning that a software license has expired or there is a problem and users must purchase additional software online to fix the problem



Infections (2) - Crypto-malware

- Crypto-malware - a more malicious form of ransomware where threat actors encrypt all files on the device so that none of them could be opened
- Once infected with crypto-malware:
 1. Connects threat actor's command and control (C&C) server to receive instructed or updated data
 2. A locking key is generated for the encrypted files and that key is encrypted with another key that has been downloaded from the C&C
 3. Second key is sent to the victims once they pay the ransom



ITNM3312, Security & Protection of Systems

Payload Capabilities (3)

- The destructive power of malware can be found in its payload capabilities
- Primary payload capabilities are to:
 1. Collect data
 2. Delete data
 3. Modify system security settings
 4. Launch attacks

ITNM3312, Security & Protection of Systems

32

Payload (3) - Collect Data

1- **Spyware** - software that gathers information without user consent

- Uses the computer's resources for the purposes of collecting and distributing personal or sensitive information such as **Keylogger** - captures and stores each keystroke that a user types on the computer's keyboard



2- **Adware** - program that delivers advertising content in manner unexpected and unwanted by the user

- Typically displays advertising banners and pop-up ads
- May open new browser windows randomly



Payload (3) - Delete Data

- **Logic bomb** - computer code that lies dormant until it is triggered by a specific logical event
- Difficult to detect before it is triggered
- Often embedded in large computer programs that are not routinely scanned



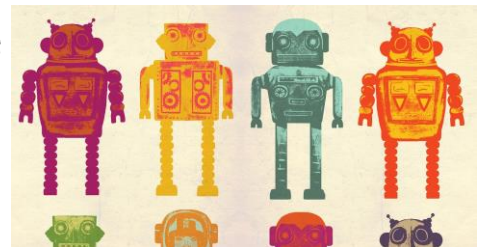
Payload (3) - Modify System Security

- **Backdoor** - gives access to a computer, program, or service that circumvents normal security to give program access
- When installed on a computer, they allow the attacker to return at a later time and bypass security settings



Payload (3) - Launch Attacks

- **Bot or zombie** - an infected computer that is under the remote control of an attacker
- Groups of zombie computers are gathered into a logical computer
 - network called a **botnet** under the control of the attacker (**bot herder**)
 - Infected zombie computers wait for instructions through a **command and control** structure from bot herders
 - A common C&C mechanism used today is HTTP, which is more difficult to detect and block



Payload (3) - Launch Attacks

- 1- Spamming: Botnets are widely recognized as the primary source of spam email. A botnet consisting of thousands of bots enables an attacker to send massive amounts of spam.
- 2- Spreading malware: Botnets can be used to spread malware and create new bots and botnets. Bots can download and execute a file sent by the attacker.
- 3- Manipulating online polls: Because each bot has a unique IP address, each "vote" by a bot will have the same credibility as a vote cast by a real person.
- 4- Denying services: Botnets can flood a web server with thousands of requests and overwhelm it to the point that it cannot respond to legitimate requests.

37

Outlines

- *Information Security Terminologies*
- *Defending Against Attacks*
 - *Difficulties*
 - *Considerations*
- *Malicious software (Malware)*
- *Psychological Approaches*

38

Psychological Approaches

- Psychological approaches goal: to persuade the victim to provide information or take action
- Attackers use a variety of techniques to gain trust without moving quickly:
 - 1- Provide a reason 2- Project confidence
 - 3- Use evasion and diversion 4- Make them laugh
- Psychological approaches often involve:
 - Impersonation, phishing, spam, hoaxes, and watering hole attacks

Psychological Approaches

1- Impersonation - attacker pretends to be someone else such as Help desk support technician, Repairperson, IT support, Manager, Trusted third party, Fellow employee



- Attacker will often impersonate a person with authority because victims generally resist saying "no" to anyone in power

Psychological Approaches

2- Phishing - sending an email claiming to be from legitimate source

- Tries to trick user into giving private information
- The emails and fake websites are difficult to distinguish from those that are legitimate



Psychological Approaches

3- Spam - unsolicited e-mail

- Primary vehicles for distribution of malware or Sending spam is a lucrative business
- Filters look for specific words and block the email
- **Image spam** - uses graphical images of text in order to circumvent text-based filters
- Often contains nonsense text so it appears legitimate

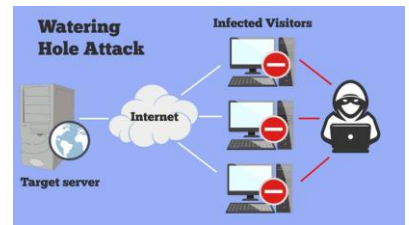


Psychological Approaches

4- **Hoaxes** - a false warning, attackers try to get victims to change configuration settings on their computers that would allow the attacker to compromise the system



5- **Watering hole attack** - a malicious attack that is directed toward a small group of specific individuals who visit the same website



Thanks